Acme Enterprise Security and Access Control Policy (v2.4)

Document ID: SEC-POL-2026-001 | Classification: Internal Authorized

1. Identity and Session Management

All employees must authenticate through Google OpenID Connect (OIDC) authorization-code flow with PKCE, state verification, and cryptographic nonce validation. Application sessions use opaque 256-bit identifiers stored strictly as SHA-256 hashes in PostgreSQL.

Session cookies must be marked HttpOnly, Secure, and SameSite=Lax. Idle sessions expire after 8 hours (28,800 seconds) and absolute session lifetime is capped at 24 hours (86,400 seconds).

2. Role-Based and Document-Level Access Control (RBAC & ACL)

The platform enforces four canonical tenant roles: Viewer, Contributor, Knowledge Admin, and System Admin. Document visibility is filtered inside SQL queries before vector or full-text ranking occurs. No unauthorized passage may ever enter an LLM prompt or search result.

Section 3: Data Retention, Soft Deletion, and Incident Response

3.1 Soft Deletion and Purge Workflow
When a document owner or Knowledge Admin deletes a document, the system sets deleted_at immediately to hide all associated chunks from hybrid search and citation resolution.
A background purge workflow permanently deletes original object storage blobs, chunks, and vector embeddings within 24 hours and records an immutable audit_events entry.

3.2 Incident Escalation and Cryptographic Rotation
Any suspected credential exposure must be reported to the Security Operations Center within 30 minutes. Session signing keys and external AI provider keys are rotated every 90 days or immediately upon security incident declaration.
Backup pg_dump archives are encrypted with AES-256-GCM and retained for 30 days.